

Clase 068 — Reconocimiento pasivo e inteligencia de fuentes abiertas

Parte: 3 — **Hacking ético y pentesting: metodología** · Fuente: *The Hacker Playbook 3* (P. Kim) y *OSINT Techniques* (M. Bazzell) 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

Objetivo

Recolectar información sobre un objetivo **sin tocarlo directamente**, usando fuentes públicas (OSINT): dominios, subdominios, empleados, tecnologías, filtraciones y metadatos. El reconocimiento pasivo construye el mapa antes de que el escáner activo levante alarmas.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Recolectar** dominios, subdominios y correos con herramientas pasivas.
2. **Consultar** registros WHOIS, DNS y certificados (crt.sh) para ampliar la superficie.
3. **Identificar** tecnologías y activos expuestos con Shodan y buscadores.
4. **Detectar** credenciales filtradas en brechas públicas para el modelado de amenazas.
5. **Documentar** los hallazgos OSINT de forma estructurada y trazable.

Temas

#	Tema	Por qué importa
1	Diferencia pasivo vs. activo	El pasivo no genera tráfico contra el objetivo
2	WHOIS y DNS	Revelan propietario, rangos y registros
3	Certificate transparency (crt.sh)	Descubre subdominios sin escanear
4	Shodan y Censys	Muestran servicios ya indexados de Internet
5	OSINT de personas	Empleados = superficie de ingeniería social
6	Metadatos de documentos	Filtran usuarios, software y rutas internas
7	Brechas y credenciales filtradas	Reutilización de contraseñas es acceso inicial

Definiciones y características

- **OSINT:** inteligencia obtenida de fuentes abiertas y legales. Característica clave: no requiere interactuar con la infraestructura del objetivo.
- **Certificate Transparency:** registros públicos de certificados TLS emitidos. Característica clave: exponen subdominios que el objetivo no publicita.

- **Shodan:** buscador de dispositivos conectados a Internet. Característica clave: indexa banners de servicios, versiones y puertos ya conocidos.
- **Google dorking:** uso de operadores avanzados de búsqueda (`site:` , `filetype:` , `intitle:`). Característica clave: encuentra documentos y paneles expuestos por error.
- **Metadatos:** información incrustada en documentos (autor, software, rutas). Característica clave: revelan nombres de usuario y estructura interna.
- **Reconocimiento pasivo:** fase que no genera tráfico dirigido al objetivo. Característica clave: minimiza la probabilidad de detección temprana.

Herramientas y preparación

En Kali Linux:

```
sudo apt update && sudo apt install -y theharvester whois dnsutils amass
pip install shodan && shodan init <API_KEY> # cuenta gratuita
```

- `theHarvester` para correos, subdominios y hosts.
- `whois` , `dig` , `host` para DNS.
- `amass enum -passive` para enumeración pasiva de subdominios.
- `crt.sh` (web) para certificados; Shodan/Censys para servicios expuestos.

 **Nota ética:** el OSINT es legal porque usa fuentes públicas, pero solo debes recopilar sobre objetivos **autorizados**. No compiles perfiles de personas fuera del alcance ni uses datos filtrados para acceder a cuentas reales fuera del laboratorio.

Laboratorio guiado

Usa un dominio **propio** o uno autorizado (por ejemplo, `example.com` para practicar comandos sin impacto).

1. WHOIS del dominio para ver registrador y fechas:

```
bash whois example.com
```

2. Registros DNS básicos:

```
bash dig example.com ANY +noall +answer dig MX example.com +short
```

3. Subdominios pasivos con crt.sh (vía web o API):

```
bash curl -s "https://crt.sh/?q=%25.example.com&output=json" | jq -r '.[].name_value' | sort -u
```

4. Enumeración pasiva con amass:

```
bash amass enum -passive -d example.com -o subs.txt
```

5. Correos y hosts con theHarvester:

```
bash theHarvester -d example.com -b bing,crtsh -l 200
```

6. Consulta Shodan sobre una IP propia:

```
bash shodan host <TU_IP_PUBLICA>
```

7. Consolida todo en una tabla de activos: dominio, subdominio, IP, servicio, fuente.

Ejercicios

1. Encuentra tres subdominios de un dominio propio usando solo crt.sh.
2. Escribe tres Google dorks para localizar documentos PDF de una organización.
3. Extrae los registros MX y explica qué proveedor de correo usan.
4. Compara el resultado de `amass -passive` con `theHarvester`: ¿qué aporta cada uno?
5. Documenta qué metadatos podrías extraer de un PDF público (autor, software).
6. Explica cómo un correo filtrado en una brecha se convierte en vector de acceso.

Reto verificable

Genera un **informe de reconocimiento pasivo** de un dominio propio con: registros WHOIS/DNS, al menos cinco subdominios con su fuente, servicios expuestos y una lista de correos/usuarios candidatos.

Criterio de aceptación: el informe lista ≥ 5 subdominios con la fuente de cada uno, incluye al menos un servicio expuesto identificado por Shodan/Censys y **no** contiene ninguna acción que haya generado tráfico dirigido al objetivo.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>theHarvester</code> no devuelve nada	Fuente saturada o sin API key; cambia <code>-b</code> a otra fuente
crt.sh sin resultados	Comodín mal escrito; usa <code>%25.dominio.com</code> (URL-encoded)
Subdominios que no resuelven	Registros históricos; valida con <code>dig</code> antes de darlos por vivos
Shodan sin datos	IP tras NAT/CDN; consulta el rango real o el CNAME
Perfilar personas de más	Fuera de alcance; limita OSINT a lo autorizado

Preguntas frecuentes

? ¿El reconocimiento pasivo es 100% indetectable? Casi. No genera tráfico contra el objetivo, pero consultas a terceros (Shodan, brechas) pueden dejar rastro en esos servicios, no en el objetivo. Aun así es mucho más sigiloso que el escaneo activo.

? ¿Es legal usar bases de datos de contraseñas filtradas? Consultar si un correo aparece en una brecha (p. ej. Have I Been Pwned) es legal e informativo. Usar esas contraseñas para acceder a cuentas reales fuera de tu laboratorio no lo es.

? ¿Qué diferencia hay entre `amass` pasivo y activo? `-passive` solo consulta fuentes de terceros; el modo activo resuelve y puede hacer brute force de DNS, generando tráfico. Para esta clase, quédate en pasivo.

? ¿Por qué importan los metadatos de documentos? Revelan nombres de usuario (que suelen coincidir con logins), versiones de software vulnerables y rutas internas útiles para fases posteriores.

Referencias

- Kim, P. *The Hacker Playbook 3*, sección de recon (2018).
- crt.sh — <https://crt.sh>
- Shodan — <https://www.shodan.io>
- theHarvester — <https://github.com/laramies/theHarvester>
- OWASP — Information Gathering — <https://owasp.org/www-project-web-security-testing-guide/>

Siguiente clase

Clase 069 - Reconocimiento activo